Experiment No. 9

Perform Web Application Vulnerability Scanning

AIM

To identify security vulnerabilities in a target web application such as SQL injection, XSS, and security misconfigurations using automated vulnerability scanning tools such as OWASP ZAP.

PROCEDURE

1. Complete web spidering of the target application (as in Experiment 8) so the scanner is aware of all pages and parameters.
2. In OWASP ZAP, select the target site and choose 'Attack > Active Scan' to begin automated vulnerability scanning.
3. Configure the scan policy to include checks for SQL Injection, Cross-Site Scripting (XSS), security misconfigurations, and outdated components.
4. Allow the active scan to send crafted test payloads to each discovered parameter and analyze the application's responses.
5. Monitor the Alerts tab for vulnerabilities as they are discovered, classified by risk level (High/Medium/Low/Informational).
6. Review each alert's details, including the affected URL, parameter, attack payload used, and recommended remediation.
7. Export the vulnerability scan report in PDF/HTML format for documentation.

SAMPLE OUTPUT

```
OWASP ZAP Active Scan Report - testapp.local
Scan duration: 00:04:52   Alerts found: 9

[High]   SQL Injection - /profile.php  param: id
[High]   Cross Site Scripting (Reflected) - /search.php  param: query
[Medium] Missing Anti-CSRF Tokens - /login.php
[Medium] X-Frame-Options Header Not Set - /
[Low]    Cookie Without Secure Flag - PHPSESSID
[Info]   Server Leaks Version Information via 'Server' header
```

RESULT

Automated vulnerability scanning of the target web application was successfully performed using OWASP ZAP, identifying High-risk SQL Injection and Cross-Site Scripting vulnerabilities along with several medium and low risk misconfigurations.